



INFORMATION SECURITY · DRAFT FOR REVIEW

Policy Set

Fourteen policies supporting vendor due diligence and SOC 2 readiness, written against the environment Centience actually operates.

Not approved. Do not release.

Every **VERIFY** marker is a statement of fact only Orville can confirm. Every **DECIDE** marker is a cadence or threshold the document cannot choose. Both must be resolved before any part of this reaches a client.

Contents

Counts show open review markers per document. Document 00 is the master policy; the rest sit beneath it and are binding to the same extent.

00	Information Security Policy	5	1
01	Access Control Policy	8	3
02	Acceptable Use Policy	6	
03	Data Classification and Handling Policy	2	
04	Data Retention and Disposal Policy	3	10
05	Encryption and Key Management Policy	5	2
06	Change Management and Secure Development Policy	8	3
07	Logging and Monitoring Policy	12	5
08	Incident Response Plan	8	3
09	Business Continuity and Disaster Recovery Plan	11	6
10	Vendor and Third-Party Management Policy	3	2
11	Risk Management Policy	2	2
12	Onboarding and Offboarding Policy	16	2
13	Sub-Processor Register	44	

VERIFY 133 statements of fact requiring confirmation · **DECIDE** 39 cadences or thresholds requiring a decision

Not included, deliberately: a risk assessment, a penetration test summary, and anything implying a SOC 2 report. The first two are records of work performed and cannot be drafted ahead of the work.

00 Information Security Policy

DOCUMENT OWNER Orville Matias, Chief Executive Officer APPROVED BY **VERIFY — approver and date**

VERSION 1.0 — draft EFFECTIVE **VERIFY — date of approval**

REVIEW Annually, and on material change to the business or environment

CLASSIFICATION Internal — releasable to clients and prospects

1. Purpose and scope

Centience operates technology governance for regulated firms. In doing so it connects to client environments, tests controls against them, and holds the resulting evidence record. Clients are subject to SEC, FINRA, NFA, NYDFS and HIPAA obligations, and they rely on Centience to handle their information accordingly.

This policy applies to **all Centience personnel, contractors and systems**, and to all client information Centience receives, processes, stores or transmits.

It is the master document. The policies listed in §7 sit beneath it and are binding to the same extent.

2. Principles

1. **Least privilege.** Access is granted for a stated purpose and removed when that purpose ends.
2. **Segregation by tenant.** Each client's data is logically separated. No control depends on staff remembering which client they are looking at.
3. **Evidence over assertion.** Where a control matters, its operation is recorded. A claim that a control operated is not the same as a record that it did.
4. **Fail closed.** Where a security control cannot be applied, the operation stops rather than proceeding unprotected.
5. **Client evidence is held in trust, not owned.** It is a custodial obligation, not an asset. See §04 and the Centience Constitution, Rule 11.
6. **Scope what is operable.** Centience does not commit to a control it cannot perform consistently.

3. Roles

Role	Held by	Responsible for
Executive owner	Orville Matias, CEO	Approval of this policy set, risk acceptance, resourcing
Security lead	VERIFY — named individual	Day-to-day operation of controls, incident coordination, access reviews
Engineering lead	VERIFY — named individual	Secure development, change management, production access
Every member of staff	—	Following this policy, completing training, reporting suspected incidents without delay

A firm of this size does not have separate security and engineering functions, and this policy does not pretend otherwise. Where one person holds two of the roles above, **the compensating control is that production changes require review by a second person** (see §06).

4. The environment

Recorded so that the policies beneath this one describe something real.

Layer	Provider	Notes
Application hosting	Vercel	Next.js application and serverless API routes
Database, auth, storage, edge functions	Supabase	PostgreSQL with row-level security; tenant isolation enforced by policy on <code>org_id</code>
AI processing	Anthropic	Model inference and Enterprise API for client AI adoption metrics
Client environment access	Microsoft Graph / Entra ID	Application registrations against client tenants
Endpoint telemetry	NinjaRMM	Contributes to shadow-AI discovery
Data loss prevention	Strac VERIFY — current status	Engaged where DLP is in a client's scope
Source control and CI	GitHub	Pull-request review required before merge
Transactional email	Resend	
CRM and marketing	HubSpot	Prospect and client contact data
Corporate productivity	Microsoft 365	Email, documents, identity for Centience staff

The authoritative list of third parties handling client data, with DPA status, is the Sub-Processor Register.

5. Client data — what Centience holds

Stated plainly, because clients ask and because it bounds every other policy.

Centience holds: – Control test results and findings, with timestamps and observed configuration – Client policies and written supervisory procedures uploaded or generated – Attestation records – Inventories of AI tools, vendors and sub-processors – Metadata about AI usage — user, tool, surface, volume, spend – Credentials and tokens for authorized connections to client environments, encrypted at rest

Centience holds AI interaction content only where a client has enabled that module, and then on the retention period that client sets. See §04.

Centience does not hold client end-customer account records, trading or position data, or client financial records, except where such data appears incidentally within a document a client uploads.

6. Compliance obligations Centience owes its clients

Centience is a **service provider** to covered institutions. Amended Regulation S-P requires those institutions to have policies reasonably designed to ensure their service providers protect customer information and notify them promptly of a breach.

Centience commits to notifying an affected client as soon as possible and no later than 72 hours after becoming aware of a breach of security resulting in unauthorized access to a system holding that client's information. This is operationalized in the Incident Response Plan.

7. The policy set

Ref	Policy
01	<u>Access Control</u>
02	<u>Acceptable Use</u>
03	<u>Data Classification and Handling</u>
04	<u>Data Retention and Disposal</u>
05	<u>Encryption and Key Management</u>
06	<u>Change Management and Secure Development</u>
07	<u>Logging and Monitoring</u>
08	<u>Incident Response Plan</u>
09	<u>Business Continuity and Disaster Recovery</u>
10	<u>Vendor and Third-Party Management</u>
11	<u>Risk Management</u>
12	<u>Onboarding and Offboarding</u>

8. Training and awareness

All staff complete security awareness training on joining and at least annually thereafter, with completion recorded. **DECIDE — training provider and annual month**

All staff acknowledge this policy and the Acceptable Use Policy on joining and on each material revision. Acknowledgements are retained as evidence.

9. Exceptions

An exception to this policy set requires a written request, a named owner, a stated business rationale, compensating controls where available, and an expiry date. Exceptions are approved by the CEO and recorded in the risk register.

An exception that reaches its expiry date without renewal is closed, and the underlying requirement applies again. An exception is a decision with a clock on it, not a permanent waiver.

10. Enforcement

Failure to comply may result in withdrawal of access and, for employees and contractors, disciplinary action up to and including termination of employment or engagement.

11. Review

This policy is reviewed at least annually by the document owner, and on any material change to the business, the environment, or the regulatory obligations of clients. The date, reviewer and outcome of each review are recorded.

01 Access Control Policy

DOCUMENT OWNER **VERIFY — security lead** VERSION 1.0 — draft · Effective **VERIFY** · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. Principle

Access is granted **for a stated purpose, at the minimum level required, to a named individual**, and removed when the purpose ends. There are no shared logins to systems holding client information.

2. Identity

Corporate identity is Microsoft Entra ID. Every member of staff has a single named account. Shared mailboxes exist but are accessed through individual identities, never through a shared password.

Multi-factor authentication is required for all staff on all corporate systems, and for all access to production systems and client environments. There is no exemption for convenience, and no standing exclusion list.

VERIFY — confirm MFA is enforced by conditional access policy with no exclusions, and attach the policy export

Platform identity. Access to the Centience platform is by named account with MFA. Microsoft SSO is available to client organizations that prefer it.

3. Levels of access

Level	What it permits	Who holds it
Staff — standard	Corporate email, documents, collaboration	All staff
Platform — operational	Client-facing platform functions within assigned client accounts	Governance engineers
Platform — administrative	Org and user administration, module configuration	VERIFY — named holders
Production infrastructure	Vercel deployment, Supabase project, secrets	VERIFY — named holders, expected to be very few
Client environment connections	Microsoft Graph application registrations against client tenants	Service identities, not individuals

Client environment access is held by service identities with scoped permissions, authorized by the client, and not by individual staff logins. Staff act through the platform, which mediates and logs the access.

4. Privileged access

Production infrastructure access is restricted to the smallest number of people who can operate the service. Each holder is named in the access register.

The Supabase service-role key bypasses row-level security. It is therefore treated as the most sensitive credential the firm holds:

- It is never present in client-side code, in the repository, or in any log
- It is held only in server-side environment configuration
- API routes using it must call the tenant guard (`requireOrgAccess`) on every request, because the database will not enforce isolation for them

That last point is a control, not a convention. Any route holding the service-role key without an explicit tenant check is a defect and is treated as one.

5. Access reviews

Access to production infrastructure, platform administration, and client environments is reviewed `DECIDE — quarterly or semi-annually`.

Each review records the date, the reviewer, the accounts examined, and any changes made. **A review with no record did not happen**, which is the single most common finding in the assessments Centience performs for clients.

`DECIDE` — choose the cadence you will actually keep. Semi-annual and performed is stronger than quarterly and skipped.

6. Joiners, movers and leavers

Governed by the Onboarding and Offboarding Policy. In summary:

- Access is provisioned from a role template, not by copying another person's access
- On role change, access is re-derived from the new role and the old access removed — not added to
- **On departure, all access is revoked the same day**, covering corporate identity, platform, production infrastructure, third-party SaaS and API tokens

Email disabled quickly and SaaS accounts left open for weeks is the recurring pattern Centience finds in client environments. It applies here too.

7. Passwords and secrets

- Corporate accounts follow Entra ID password policy with MFA enforced `VERIFY — current settings`
- A password manager is required for any credential not federated through SSO `VERIFY — which one`
- Secrets are never committed to source control, shared over email or chat, or stored in documents
- Production secrets live in the platform environment configuration and are accessible only to holders of production access

Credential rotation occurs on staff departure, on suspected compromise, and `DECIDE — on a fixed schedule, or on event only`.

8. Remote access and devices

Staff work from firm-managed devices. Device requirements — disk encryption, screen lock, endpoint protection, supported OS with current patches — are set in the Acceptable Use Policy and monitored through NinjaRMM.

VERIFY — whether any staff or contractors use unmanaged personal devices for firm work, and if so what compensating controls apply. Answer honestly; a client DDQ will ask.

9. Client access to their own data

Client users access only their own organization. Isolation is enforced at the database layer by row-level security keyed on organization, and at the API layer by an explicit tenant guard.

Partner organizations — compliance consultancies and advisers working with a shared client — receive access only where the client has authorized it, scoped to that client.

10. Exceptions

Per [Information Security Policy §9](#): written, owned, justified, time-limited, recorded.

02 Acceptable Use Policy

DOCUMENT OWNER **VERIFY — security lead** VERSION 1.0 — draft · Effective **VERIFY** · Review annually

CLASSIFICATION Internal — releasable to clients and prospects

ACKNOWLEDGEMENT Required on joining and on each material revision

1. Scope

Applies to every employee and contractor, on every device used for Centience work, and to every system holding Centience or client information.

2. General conduct

Firm systems are provided for firm business. Incidental personal use is permitted where it does not interfere with work, consume meaningful resource, or introduce risk.

You must not:

- Share your credentials, or use anyone else's
- Disable or circumvent a security control — endpoint protection, MFA, disk encryption, update policy
- Install software on a firm device outside the approved process
- Move client information to personal storage, personal email, or an unapproved service
- Access client data you have no current business reason to access

That last point deserves emphasis. Centience holds a map of which client organizations are weak where. Browsing it out of curiosity is a breach of this policy, not a minor lapse.

3. Devices

Every device used for firm work must have:

- Full-disk encryption enabled
- A screen lock engaging after no more than 15 minutes
- Endpoint protection running and reporting
- A supported operating system with current security updates
- Remote wipe available for firm data

Devices are enrolled in management through NinjaRMM. **VERIFY — confirm enrolment covers all staff devices, and whether any exceptions exist**

Report a lost or stolen device **immediately** — see the [Incident Response Plan](#). There is no penalty for reporting quickly and no excuse for reporting late.

4. Email and communications

- Verify unexpected requests for payment, credentials or data changes through a second channel. Do not rely on the email itself.
- Report suspected phishing rather than deleting it.

- Do not use personal messaging apps for firm business involving client information.
-

5. AI tools

Centience sells AI governance. Its own use of AI must be at least as well governed as what it asks of clients.

Approved tools are listed in the AI tool inventory and maintained by **VERIFY — owner**. Current approved tools: **VERIFY — list them. Claude, Granola and the development tooling are in use and should be named explicitly if approved.**

Rules:

1. **Use firm-provisioned enterprise accounts.** Not personal subscriptions, not personal accounts on a firm device.
2. **Client information may be submitted only to approved tools**, under the firm's enterprise tenancy, where the provider does not train on the data and the interaction is retained under firm control.
3. **Client end-customer personal information — names, account numbers, government identifiers — must not be submitted** unless the specific workflow has been approved and the handling documented.
4. **Do not act on AI output affecting a client without human review.** An AI-drafted finding, policy or client communication is a draft until a person has checked it.
5. **Meeting recording and transcription requires participant consent** and the retention period set in §04. Client calls are client information.

Shadow AI. A tool not on the approved list is not approved, regardless of how useful it is. The route to approval is to ask — it is fast, and the alternative is that the firm's own discovery sweep finds it and records it as a finding against us.

6. Working outside the office

Do not display client information on screens visible to others in public spaces. Use a trusted network or a mobile connection rather than open public Wi-Fi where practical.

7. Departure

On leaving, return all firm devices and firm data. Do not retain client information in any form. Access is revoked on the final working day; see Onboarding and Offboarding.

8. Reporting

Report anything that looks like a security problem — a suspicious message, an unexpected prompt, an access you should not have, a file where it should not be — to **VERIFY — reporting channel and address**.

Report early and be wrong rather than late and right. Nobody has ever been penalised at this firm for raising something that turned out to be nothing.

9. Acknowledgement

I have read and understood this policy and agree to comply with it.

Name · Signature · Date

03 Data Classification and Handling Policy

DOCUMENT OWNER **VERIFY — security lead** VERSION 1.0 — draft · Effective **VERIFY** · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. Why this exists

Centience holds information belonging to regulated firms, and those firms are accountable for it. Classification determines how each kind of information is stored, who may see it, how long it is kept, and what happens when something goes wrong.

2. The four classes

Class 1 — Client Confidential

The most sensitive category and the reason the rest of this policy set exists.

Includes: control test results and findings; observed configuration from a client environment; client policies and written supervisory procedures; attestation records; AI interaction content where that module is enabled; credentials and tokens for client environments; any client end-customer personal information appearing in an uploaded document.

Handling: – Stored only in the platform database, segregated by tenant, or in the firm's own Microsoft 365 where a working copy is unavoidable – Encrypted in transit and at rest – Accessible only to staff with a current business reason – Never copied to personal storage, personal email, or an unapproved service – Never used in a sales or marketing artifact without written client consent – Aggregated only under opt-in consent and never in a form reasonably attributable to an organization — Constitution Rule 12

Class 2 — Centience Confidential

Source code, infrastructure configuration, commercial terms, pricing, internal strategy, personnel records.

Restricted to staff with a business need. Not shared externally without approval.

Class 3 — Internal

Day-to-day operational material with no client or commercial sensitivity. Available to all staff. Not published.

Class 4 — Public

Website content, published articles, marketing collateral. No restriction.

3. Credentials are their own problem

Client environment credentials and API tokens are Class 1, but they carry a further rule: **they are encrypted at rest with a dedicated key, and the system fails closed if that key is unavailable.**

In production, an attempt to store a credential without encryption raises an error and the operation stops. It does not fall back to plaintext. See [Encryption and Key Management](#).

4. Tenant segregation

Client data is separated by organization at the database layer using row-level security. Application routes that bypass that layer — those using the service-role key — must perform an explicit tenant check on every request.

No control here depends on a person remembering which client they are looking at.

5. Sharing with third parties

Class 1 information reaches a third party only where:

1. The third party is in the Sub-Processor Register, **or** the client has specifically authorized the disclosure
2. A written agreement covering confidentiality and data protection is in place
3. The disclosure is limited to what the purpose requires

Partner access. Compliance consultancies and advisers may be granted access to a shared client's data, scoped to that client, where the client has authorized it. Partner access is client-authorized, never assumed from the commercial relationship.

6. Where client information may live

Location	Permitted classes	Notes
Platform database (Supabase)	1, 2, 3	Primary store. RLS-segregated
Firm Microsoft 365	1, 2, 3	Working copies and correspondence. Retention per §04
GitHub	2, 3	No Class 1. No client data, no secrets
HubSpot	2, 3	Contact and pipeline data. No client evidence
Personal devices or storage	none	Prohibited for Class 1 and 2
Unapproved SaaS or AI tools	none	Prohibited for Class 1 and 2

7. Labelling

Documents produced for clients carry a classification marking in the footer. Internal documents carry one where ambiguity is possible.

Absence of a label does not mean public. Unlabelled material defaults to Internal, and anything containing client information is Class 1 whether or not it says so.

8. Disposal

Per the Data Retention and Disposal Policy.

04 Data Retention and Disposal Policy

DOCUMENT OWNER VERIFY — security lead VERSION 1.0 — draft · Effective VERIFY · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. The governing principle

Client evidence is held in trust, not owned. Centience is a custodian of a record that belongs to the client. The concentration of that record across many regulated firms is a custodial obligation, not a commercial asset. This is Rule 11 of the Centience Constitution and it governs everything below.

2. Retention schedule

Data	Retained	Basis
Control test results and findings	DECIDE — recommend the client's applicable record period, default 6 years	Client's own recordkeeping obligation
Observed configuration and evidence items	As above	As above
Client policies and WSPs	Life of engagement + DECIDE	Client record
Attestation records	As findings	Supervisory evidence
AI interaction content	Set by the client at onboarding. 30-day auto-delete and multi-year retention are equally supported.	Client's determination
AI usage metadata — user, tool, surface, volume, spend	DECIDE	Operational and billing
Client environment credentials	Life of engagement. Destroyed on termination	Operational necessity
Platform audit logs	DECIDE — recommend minimum 1 year	Security and SOC 2
Corporate email and documents	DECIDE	Business record
Meeting recordings and transcripts	DECIDE — recommend short; these are client communications	See §6
Prospect and marketing contact data	Until opt-out or DECIDE	Legitimate interest

On the AI content row. Whether AI prompts constitute required records is genuinely unsettled. Centience does not take a position on a client's behalf, does not default them into retention they did not choose, and will not manufacture a recordkeeping obligation in order to enlarge its own scope. The client decides with their counsel; the platform implements whatever they decide.

3. Termination

On termination of an engagement, the client receives **a complete export of their evidence record** in a portable format — findings, evidence, attestations, policies and decision history.

The export is provided within **DECIDE — recommend 30 days** of the termination date, at no additional charge.

Any copy Centience retains to defend its own work must be agreed in the contract in advance. It is never asserted after the fact. Where such a copy is retained:

- It is limited to what is necessary to evidence the work performed
- It is held under the same protections as live client data
- It is destroyed at the end of the agreed period
- The client is told, in the contract, that it exists

Client environment credentials are destroyed on termination, and the corresponding application registrations in the client's tenant are disabled. The client should also revoke consent on their side; Centience confirms in writing when its side is complete.

4. Disposal

- **Database records** are deleted through the application, which removes dependent records rather than orphaning them
 - **Backups** age out on the backup retention cycle; a record deleted from production persists in backup until that cycle completes, and clients are told so
 - **Documents** in Microsoft 365 are deleted through retention policy, not manually
 - **Devices** are wiped before disposal or reassignment, with the wipe recorded
 - **Paper**, where any exists, is shredded
-

5. Legal hold

Where litigation, an examination or a regulatory inquiry is reasonably anticipated, **routine deletion stops** for the affected records until the hold is lifted. A hold is applied by the CEO, recorded with its scope and date, and reviewed **DECIDE — quarterly** while it remains in force.

A legal hold overrides every retention period in §2, including a client-set short retention on AI content.

6. Meeting recordings

Client meetings are recorded and transcribed using Granola, which processes that content as a sub-processor.

- Participants are informed that recording is taking place
- Transcripts are retained for **DECIDE — recommend the shortest period that serves the purpose**
- Recordings and transcripts of client meetings are Class 1

VERIFY — confirm the current Granola retention setting and that participant notice is given consistently. This is the most likely place for a gap between practice and policy, and a client DDQ will reach it.

7. Aggregate use

Client control data may be aggregated only under **explicit opt-in consent**, and never in a form reasonably attributable to an organization. Silence is not consent.

Constitution Rule 12. It exists because the ordinary way this rule fails is not a decision to break it but the absence of one.

05 Encryption and Key Management Policy

DOCUMENT OWNER VERIFY — engineering lead VERSION 1.0 — draft · Effective VERIFY · Review annually

CLASSIFICATION Internal — releasable to clients and prospects

1. In transit

All connections carrying Centience or client information use TLS 1.2 or higher.

- The web application and API are served over HTTPS only, with HSTS
- Connections to Supabase, Microsoft Graph, Anthropic and all other providers are TLS
- Plain HTTP is not accepted; requests are redirected

2. At rest

Store	Encryption
Platform database (Supabase)	Encrypted at rest by the provider (AES-256)
Object storage	Encrypted at rest by the provider
Backups	Encrypted at rest by the provider
Staff devices	Full-disk encryption required — Acceptable Use §3
Microsoft 365	Encrypted at rest by the provider

3. Client credentials — application-layer encryption

Credentials and tokens for client environments receive a second layer of protection above the database's own encryption.

They are encrypted by the application before storage, with a dedicated key held in environment configuration and never in the repository.

The control that matters most is the failure behaviour:

In production, if the encryption key is unavailable, the write **fails with an error**. It does not store the credential in plaintext.

This is enforced in code rather than by convention (`lib/crypto.ts` , `encryptForStorage`). Outside production, where no client data exists, plaintext is permitted for local development only.

VERIFY — confirm `CREDENTIAL_ENCRYPTION_KEY` is set in the production environment. If it is not, production writes are failing closed, which is correct but will be visible as errors; and until it is set the control is untested.

4. Key management

Where keys live	Platform environment configuration, accessible only to holders of production access
Who can read them	VERIFY — named holders, expected to be very few
In source control	Never. No key, token or secret is committed
In logs	Never. Credential values are excluded from all logging
Rotation	On suspected compromise, on departure of a holder, and DECIDE — on a fixed schedule, or on event only

Rotation procedure for the credential encryption key requires re-encrypting stored credentials under the new key. DECIDE — document the procedure before it is needed, not during an incident.

5. The service–role key

The Supabase service–role key bypasses row–level security and is the most consequential secret the firm holds. Its handling is set out in [Access Control §4](#).

Restated here because it belongs in both places: **any API route holding this key must perform an explicit tenant check on every request**, because the database will not do it for them.

6. Cryptographic standards

- Symmetric encryption: AES–256
- Hashing: SHA–256 or stronger
- Passwords: handled by the identity provider; Centience does not store password material
- No custom or in–house cryptography. Platform and standard library primitives only

7. Client–side

No client information is stored in browser local storage beyond what a session requires. Session tokens are held per the authentication provider’s defaults and are not persisted beyond the session lifetime. VERIFY

06 Change Management and Secure Development Policy

DOCUMENT OWNER **VERIFY — engineering lead** VERSION 1.0 — draft · Effective **VERIFY** · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. Principle

Every change to production is **traceable to a request, reviewed by a second person, tested, and reversible**. A small team does not get an exemption from this; it gets a simpler version of it.

2. The path to production

Stage	Control
Branch	Work happens on a branch, never directly on <code>main</code>
Pull request	Every change reaches <code>main</code> through a pull request describing what changed and why
Review	Approved by someone other than the author before merge
Automated checks	Build must pass. Tests must pass VERIFY — confirm CI runs the suite and blocks merge on failure
Merge	Squash merge to <code>main</code> , retaining the PR record
Deploy	Automatic on merge to <code>main</code> via Vercel
Rollback	Redeploy of the previous build

The pull request history is the change record. At the time of writing there are more than eighty merged pull requests on the platform, each carrying its description, diff and approval — a stronger trail than most firms of this size can produce.

VERIFY — the single most important item in this policy: confirm that branch protection on `main` actually requires an approving review, and that it cannot be bypassed. If the CEO can merge his own PR unreviewed, this policy is aspirational and a SOC 2 auditor will find it in the first hour. Either enable the protection or describe the compensating control honestly.

3. Separation of duties

In a firm this size the author and the deployer are often the same person. The compensating control is that **the reviewer is not the author**, and that deployment is automated from an approved merge rather than performed by hand.

Where a change must ship without review — a production outage, a security fix — it is deployed, then **reviewed retrospectively within one business day**, and the exception is recorded. An emergency change that is never reviewed is an unrecorded change.

4. Environments

Environment	Data	Access
Local development	Synthetic or anonymized only. No client data	Developers
Preview	Per-branch deployments. VERIFY — confirm previews do not connect to the production database	Developers
Production	Live client data	Restricted per Access Control §4

Client data is never copied into a non-production environment. Where a production-like dataset is needed, it is synthetic.

5. Secure development

- **No secrets in source control.** Secret scanning is enabled on the repository **VERIFY**
- **Dependencies** are monitored for known vulnerabilities, and security updates applied on the schedule in §7
- **Input validation** on all API routes, particularly those accepting uploaded documents
- **Tenant isolation is a review item.** Any change touching data access is reviewed specifically for whether isolation still holds
- **Authentication and authorization changes** receive additional scrutiny and are never merged without review

6. Testing

The platform carries a test suite of **VERIFY — current count; 64 test files as of September 2026** files.

Tests must pass before merge. Once change management is in scope for SOC 2, "tests pass" becomes an auditable assertion, so a suite that is red or skipped is a finding rather than a nuisance. **VERIFY — confirm the suite currently runs green in CI.**

7. Vulnerability and patch management

Severity	Remediated within
Critical	DECIDE — recommend 7 days
High	DECIDE — recommend 30 days
Medium	DECIDE — recommend 90 days
Low	Next convenient release

Applies to application dependencies, and to staff devices through NinjaRMM.

Where a vulnerability cannot be remediated within the target, it is recorded as an exception with an owner, a compensating control and an expiry — per Information Security Policy §9.

8. Database changes

Schema changes are applied through migrations held in source control and subject to the same review as application code. **A migration applied directly to production outside the migration path is an incident**, not a shortcut.

9. Third-party code

New dependencies are added deliberately, with consideration of maintenance status, licence and transitive footprint. A dependency that reaches client data is subject to Vendor and Third-Party Management.

07 Logging and Monitoring Policy

DOCUMENT OWNER VERIFY — engineering lead VERSION 1.0 — draft · Effective VERIFY · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. Principle

If a privileged action cannot be attributed to a person, a time and a target, it did not happen in a way the firm can defend.

2. What is logged

Source	Captured	Retention
Application — authentication	Sign-in, sign-out, failure, MFA challenge	DECIDE — recommend ≥1 year
Application — privileged actions	Actor, timestamp, target, action. Org and user administration, module configuration, connector changes, access to client evidence	DECIDE — recommend ≥1 year
Control testing	Every check run, with result, timestamp and observed configuration	Per client retention — §04
Infrastructure (Vercel)	Request and function logs	Provider default VERIFY
Database (Supabase)	Connection and query logs	Provider default VERIFY
Corporate identity (Entra ID)	Sign-in and audit logs	VERIFY — current M365 licence retention
Endpoints (NinjaRMM)	Device state, patch status, software inventory	VERIFY

Never logged: credential values, encryption keys, session tokens, or client end-customer personal information.

3. Privileged action logging — current state

VERIFY — and this one needs an honest answer.

The platform has an audit logging module (`lib/audit.ts`), but as of the September 2026 review it was referenced in only one place. SOC 2 will expect privileged action logging with actor, timestamp and target **across the administrative surface**, and Constitution Rule 11 implies the same for any access to client evidence.

Until that coverage exists, this policy describes an intention rather than a control. **Either extend the coverage before this policy is released, or describe the current state accurately and give the remediation date.**

Publishing the stronger version and being found out is materially worse than publishing the honest one.

This is tracked in `../platform/completeness-gap-list.md` §6.

4. Monitoring and alerting

Condition	Alert to	Response
Application error rate above threshold	VERIFY — channel	Investigate within DECIDE
Failed authentication cluster	VERIFY	Investigate; consider incident
Scheduled control re-scan failure	VERIFY	Investigate same business day — clients are relying on continuous testing
Credential encryption failure	VERIFY	Immediate. Indicates key unavailability; writes are failing closed
Provider status incident	VERIFY	Per BCDR

DECIDE — this firm does not have 24/7 monitoring and should not claim it. State the monitored hours plainly. Business-hours monitoring, honestly described, is defensible; an implied NOC is not.

5. Review

Logs are reviewed **DECIDE — cadence** for anomalies, and on any incident or investigation. The review is recorded: date, reviewer, scope, outcome.

Choose a cadence that will actually be kept. An unreviewed log is still useful forensically, but a policy that promises weekly review and delivers none is a finding.

6. Integrity

Logs are held in systems where staff cannot alter historical entries. Deletion of log data before its retention period is a privileged action requiring CEO approval and is itself recorded.

7. Client-facing evidence

Control test results are not merely logs — they are the client's evidence record. They are timestamped at production, retained per the client's schedule, exportable on request, and covered by the custody obligations in Data Retention and Disposal.

08 Incident Response Plan

DOCUMENT OWNER VERIFY — security lead

VERSION 1.0 — draft · Effective VERIFY · Review annually, and after every Severity 1 or 2 incident

CLASSIFICATION Internal — releasable to clients and prospects

1. Scope

Any event that compromises, or may compromise, the confidentiality, integrity or availability of Centience or client information. Includes suspected events. **A suspicion is reported and triaged; it is not filtered at source by the person who noticed it.**

2. Severity

	Definition	Examples
Sev 1	Confirmed unauthorized access to client information, or total service loss	Credential compromise with evidence of use; database exposure; ransomware
Sev 2	Credible risk of unauthorized access, or major degradation	Lost unencrypted device; phishing with credentials entered; tenant isolation defect; sub-processor breach affecting us
Sev 3	Security-relevant, contained, no client data at risk	Blocked phishing; failed intrusion attempt; minor misconfiguration found and fixed
Sev 4	Informational	Policy violation with no data impact

When severity is uncertain, treat it as the higher one until the facts say otherwise. Downgrading later is cheap; discovering you under-triaged is not.

3. Roles

Role	Held by	Responsible for
Incident Lead	VERIFY	Running the response, declaring severity, deciding closure
Executive	Orville Matias, CEO	Client and regulatory notification decisions, external communication
Technical Lead	VERIFY	Containment, evidence preservation, remediation
Scribe	Assigned at declaration	The timeline. Every action, decision and time

One person may hold more than one role in a firm this size, **except that the Executive role for notification decisions is never delegated to the person who caused or discovered the incident.**

4. Process

Report

Anyone, immediately, to **VERIFY — channel and out-of-hours contact**. No triage by the reporter.

Declare

Incident Lead confirms and assigns severity. The clock starts here and is recorded.

Contain

Stop the bleeding before understanding it fully. Revoke credentials, disable accounts, isolate devices, disable connectors.

Preserve evidence while containing. Do not wipe a compromised device before it has been imaged; do not delete logs to clean up.

Assess

- What data, whose, how much, over what period?
- Client information involved? Which clients?
- Client end-customer personal information involved?
- Is it ongoing?

Notify

Per §5. **The clocks start at discovery, not at the end of the investigation.**

Remediate

Fix the cause, not just the symptom. Verify the fix. Record what was done.

Close

Incident Lead confirms containment and remediation are complete and evidenced.

Review

Within **DECIDE — recommend 10 business days** for Sev 1 and 2: what happened, what worked, what did not, what changes, who owns each change and by when. **Blameless on people, unsparing on process.**

5. Notification obligations

5.1 To clients — the 72-hour commitment

Centience is a service provider to covered institutions. Amended Regulation S-P requires those institutions to have policies reasonably designed to ensure their service providers notify them promptly of a breach.

Centience notifies an affected client as soon as possible and no later than 72 hours after becoming aware of a breach of security resulting in unauthorized access to a system holding that client's information.

This is a commitment Centience makes and is measured against. The 72 hours runs from **awareness**, not from confirmation, not from completion of the investigation.

The first notification does not need to be complete. It needs to be on time, accurate about what is known and honest about what is not.

Initial notification contains: what happened, when discovered, what information is involved so far as known, what has been done, what the client should consider doing, and who to contact.

5.2 Clients' own downstream obligations

A client receiving our notification may owe their own customers notification under Regulation S-P **within 30 days** of determining that sensitive customer information was, or was reasonably likely to have been, accessed without authorization.

Their 30-day clock may depend on our 72-hour notice. That is the reason the commitment above is firm, and why it is not softened for convenience during an incident.

Centience supports the client's assessment with the facts they need to make their own determination.

Centience does not make that determination for them, and does not advise on whether their obligation is triggered — that is their counsel's judgement.

5.3 Other

Law enforcement	At the CEO's discretion, on advice
Cyber insurance	Per the policy's notification requirements VERIFY — carrier, policy number, notification deadline
Regulators	Centience is not itself a registrant. Obligations arise through client contracts
Sub-processors	Where their systems are implicated, engaged immediately

6. If the incident is at a sub-processor

Centience remains accountable to its clients for information held by its sub-processors.

On notification from a provider: assess exposure to Centience data, assess which clients are affected, and **run §5.1 on our own clock**. The 72 hours runs from the moment Centience becomes aware, not from the moment the sub-processor completes their investigation.

The Sub-Processor Register records the notification commitment obtained from each provider.

7. Communication

All external communication about an incident goes through the CEO. Staff do not discuss incidents with clients, press or on social media.

Internal coordination uses **VERIFY — channel**. **Where firm systems may be compromised, coordination moves to an out-of-band channel** agreed in advance. **DECIDE — name it now; deciding during an incident is too late.**

8. Testing

This plan is exercised at least annually through a tabletop involving all named roles, with the date, participants, scenario and findings recorded. **DECIDE — month**

An untested plan is a document, not a capability. The first Severity 1 should not be the first time anyone has read this.

9. Contacts

VERIFY — complete before release, and keep a copy accessible outside firm systems

Incident Lead	
Executive	Orville Matias ·
Technical Lead	
Cyber insurance	
External counsel	
Forensics provider	

09 Business Continuity and Disaster Recovery Plan

DOCUMENT OWNER Orville Matias, Chief Executive Officer

VERSION 1.0 — draft · Effective **VERIFY** · Review annually, and after any invocation

CLASSIFICATION Internal — releasable to clients and prospects

1. Scope and honest framing

Centience is a small firm operating on managed cloud infrastructure. It does not run data centres, and its continuity posture rests largely on provider resilience plus the firm's ability to work from anywhere.

This plan says so rather than implying capability the firm does not have. A client's due diligence reviewer will respect an accurate small-firm plan and will find an inflated one immediately.

2. What the business must be able to do

In priority order:

1. **Protect client data.** Availability failures are recoverable; confidentiality failures are not.
2. **Continue control testing and evidence capture,** because clients rely on it being continuous.
3. **Respond to client incidents,** including the 72-hour notification commitment, which does not pause because Centience has its own problem.
4. Restore platform access for clients.
5. Resume normal service delivery.

3. Recovery objectives

	Target	Basis
RTO — platform availability	DECIDE — recommend 24 hours	Provider-dependent
RPO — maximum data loss	DECIDE — recommend ≤1 hour	Depends on Supabase point-in-time recovery being enabled
Incident response capability	Immediate, always	Does not depend on platform availability
Client notification capability	Immediate, always	Must survive loss of firm email — see §6

VERIFY — the critical item: confirm whether Supabase point-in-time recovery is enabled on the production project, and the backup retention window. The RPO above is not achievable without it, and this is the first technical question a reviewer will ask about this plan.

4. Scenarios

4.1 Hosting provider outage (Vercel)

Application unavailable; data intact. **Response:** confirm via provider status, notify clients if beyond **DECIDE**, monitor. No action restores service faster than the provider. **Client impact:** platform inaccessible. Scheduled control testing resumes on recovery.

4.2 Database provider outage (Supabase)

Application unavailable; data intact unless the incident is destructive. **Response:** as above. If data loss is indicated, restore from point-in-time backup to a new project and repoint the application. **DECIDE — the restore procedure should be written down and rehearsed before it is needed. §8.**

4.3 Data corruption or destructive error

Bad migration, erroneous deletion, or compromise. **Response:** stop writes, identify the last good point, restore to a new environment, verify integrity, repoint. **Treat as a security incident until ruled out** — see Incident Response.

4.4 Loss of a key person

A firm this size has real key-person concentration. **Response:** production access is held by more than one person **VERIFY — confirm, and if it is currently held by one person, that is the single highest-impact finding in this plan and should be fixed this week**. Credentials are recoverable through the password manager's recovery process. Client relationships are documented in the CRM.

4.5 Loss of office or premises

Minimal impact. Staff work from managed devices on cloud services. No firm data is held only on premises. **VERIFY**

4.6 Sub-processor failure

An AI provider, DLP provider or telemetry provider becomes unavailable or is breached. **Response:** per Vendor Management and, where client data is implicated, Incident Response §6. Degrade honestly — **a check that cannot run is reported as unable to run, never as passing.**

4.7 Ransomware or compromise of firm systems

Response: Incident Response Plan, Severity 1. Isolate, preserve evidence, restore from backup, rotate all credentials including client environment credentials. **Do not pay without CEO and counsel involvement.**

5. Backups

Platform database	Provider-managed automated backup. VERIFY — frequency, retention, PITR status
Object storage	Provider-managed VERIFY
Source code	GitHub, distributed across developer clones
Microsoft 365	Provider retention plus VERIFY — third-party backup in use?
Infrastructure configuration	In source control where possible; secrets in environment configuration VERIFY — are secrets backed up anywhere recoverable?

A backup that has never been restored is an assumption, not a control. See §8.

6. Communication during disruption

Staff	VERIFY — primary and out-of-band channel
Clients	Email, plus direct contact for materially affected clients
If firm email is unavailable	DECIDE — name the alternative now. The 72-hour client notification commitment does not pause because Microsoft 365 is down.

A current client contact list is maintained and accessible outside firm systems. **VERIFY**

7. Invocation

The CEO invokes this plan. On invocation: record the time, assign the roles from the Incident Response Plan, open a timeline, and notify staff.

8. Testing

Test	Frequency	Records
Backup restore — restore to a scratch environment and verify integrity	DECIDE — recommend semi-annually	Date, performer, data restored, time taken, issues
Tabletop exercise	Annually	Date, participants, scenario, findings
Key-person absence walk-through	Annually	Confirm a second person can perform each critical task

The restore test is the one that matters. A documented restore that actually happened is the difference between this plan and a wish. Clients ask for the date of the last successful restore, and Centience asks its own clients the same question.

VERIFY — has a restore ever been performed? If not, do one before this plan is released, and record it.

9. Dependencies on this plan

Clients relying on Centience for continuous control testing should understand that a platform outage suspends testing but does not lose evidence already captured. Where a client's own obligations require continuity assurances, those are set in the engagement agreement.

10 Vendor and Third-Party Management Policy

DOCUMENT OWNER **VERIFY — security lead** VERSION 1.0 — draft · Effective **VERIFY** · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

1. Principle

Centience assesses its clients' third-party exposure. It holds itself to the same standard, and this policy is written knowing that clients will compare the two.

Outsourcing a function does not outsource accountability for it.

2. Tiers

Tier	Definition	Diligence	Review
Critical	Handles Class 1 client information, or its failure stops service	Full, before engagement	Annually
Important	Handles Centience confidential data, or its failure degrades service	Proportionate	DECIDE — recommend every 2 years
Standard	No sensitive data, easily replaced	Basic	On material change

Tiering is recorded in the Sub-Processor Register and reviewed when a provider's role changes.

3. Before engagement

For Critical and Important providers:

1. **What data will they hold**, of what classification, and where geographically
2. **Security posture** — SOC 2 Type II or equivalent; where none exists, a documented alternative assessment and a rationale for proceeding
3. **Sub-processors** — who do they rely on? A provider that cannot answer this is itself a finding
4. **Breach notification** — contractual commitment, and the window
5. **Data handling on termination** — export and deletion
6. **Business continuity** — their resilience posture
7. **Contractual terms** — confidentiality, data protection, right to audit or to receive assurance reports

Approval for a Critical provider rests with the CEO.

4. Reading a SOC 2 report properly

A SOC 2 report is filed by most firms and read by few. Centience reads them, and checks:

- **Type I or Type II.** A Type I describes design at a point in time. A Type II covers operating effectiveness over a period and is materially more informative
- **The period covered**, and whether it is current

- **The scope** — does it cover the service actually consumed, or a different product from the same vendor?
- **Complementary user entity controls** — the things the report assumes we operate. These are obligations transferred to us and are frequently ignored
- **Exceptions in the testing**, and the auditor's opinion on them
- **The sub-service organizations** carved out of scope

Findings are recorded against the provider. A report with material exceptions relevant to our use is escalated to the CEO.

The platform's own `soc2-reader` performs this for clients. The firm uses the same discipline on its own suppliers.

5. The Reg S-P expectation, applied outward

Centience's clients are covered institutions whose obligations flow down. Centience therefore requires of its own Critical providers:

Notification as soon as possible and no later than 72 hours after they become aware of a breach of security resulting in unauthorized access to a system holding information we hold on behalf of clients.

Where a provider will not contract to this, the position is documented: what was requested, what was obtained, and why proceeding is reasonable. **A contractual commitment is the cleanest route but is not the only acceptable one** — the amended rule requires policies reasonably designed to achieve the outcome, not a specific instrument. Documented notice of the expectation, with evidence it was sent and acknowledged, can also support a reasonably designed program.

The commitment obtained from each provider is recorded in the register.

6. Ongoing review

Annually for Critical providers:

- Re-collect the SOC 2 report **before the current one lapses** — a report that expires unnoticed is the most common vendor-management finding in the assessments Centience performs
- Confirm the sub-processor list has not materially changed
- Confirm the service consumed is still in scope of the assurance held
- Review any incidents involving the provider
- Confirm the commercial relationship still warrants the access held

Report expiry dates are diarised. **VERIFY — where? The platform's own vendor register should hold this, and using it is both correct and a useful demonstration.**

7. Sub-processor changes

Where a Critical provider adds a sub-processor materially affecting client data, the change is assessed and the Sub-Processor Register updated.

Clients are notified of material sub-processor changes **DECIDE — notification commitment and window; many client agreements will require this, so decide it before a client requires it**.

8. Termination

On ending a provider relationship: confirm deletion of Centience and client data, retrieve any data held, revoke API access and credentials, remove them from the register, and record the date.

9. AI providers specifically

AI providers receive additional scrutiny, because the questions are new and the answers move:

- **Training.** Is submitted data used for model training? Is that contractual or a policy statement that may change?
- **Retention.** How long is submitted data held, where, and can we control it?
- **Sub-processors.** The chain behind a model provider is frequently longer than the buyer assumes and is rarely enumerated in the marketing material
- **Enterprise versus consumer terms.** The protections differ substantially, and only the enterprise tier typically offers the API access and contractual commitments required

The relevant question is not only what the provider's policy says today, but what latitude the policy language preserves.

11 Risk Management Policy

DOCUMENT OWNER Orville Matias, Chief Executive Officer VERSION 1.0 — draft · Effective VERIFY · Review annually
CLASSIFICATION Internal — releasable to clients and prospects

This is the policy describing how risk is managed. It is not a risk assessment. The assessment is a record of an exercise performed on a date by named people, producing findings. It cannot be written in advance. See `README.md` §2.

1. Purpose

To identify, assess, treat and monitor risks to Centience's information, its service, and the client information it holds.

2. Scope

Information security, operational, third-party and regulatory risk affecting Centience or the client data it holds. Commercial and strategic risk sit with the CEO outside this policy.

3. The cycle

Identify → Assess → Treat → Record → Monitor → Review

Risks are identified from the annual assessment, incidents and near-misses, vulnerability and monitoring output, vendor reviews, client due diligence questionnaires, regulatory change, and material change to the business or environment.

Anyone may raise a risk. A risk raised by a member of staff is recorded whether or not it is ultimately accepted.

4. Assessment

Each risk is assessed on **likelihood** and **impact**, each Low / Medium / High, producing an inherent rating. Existing controls are then considered to produce a residual rating.

	Low impact	Medium impact	High impact
High likelihood	Medium	High	Critical
Medium likelihood	Low	Medium	High
Low likelihood	Low	Low	Medium

Impact is assessed against client harm first, then regulatory exposure, then commercial loss — in that order, because a client's regulatory exposure is the thing Centience is trusted with.

5. Treatment

Option	Meaning
Mitigate	Implement or strengthen a control
Transfer	Insurance or contractual allocation
Avoid	Stop the activity
Accept	Take it, deliberately, with a record

Every treatment has a **named owner** and a **target date**. An unowned treatment is not a treatment.

6. Acceptance

A deliberate acceptance requires: the risk, the rationale, the residual rating, a **named accepting owner**, and an **expiry date**.

Acceptance authority:

Residual	Accepted by
Low	Security lead
Medium	Security lead, notified to the CEO
High or Critical	CEO

An acceptance that reaches expiry without renewal reopens. The risk returns to the register as untreated.

This is the same standard the platform applies for clients, and for the same reason: *a risk accepted deliberately, with a named owner, a rationale and a review date, reads as governance. A red light with no decision record reads as neglect. The facts are identical; the conclusion an examiner draws is not.*

7. The register

A single risk register is maintained, holding for each risk: identifier, description, category, owner, inherent rating, controls, residual rating, treatment, target date, status, and — where accepted — the acceptance record and expiry.

VERIFY — where the register lives. The platform has the workflow for exactly this. Using it is both operationally sensible and a demonstrable case study.

8. The annual assessment

At least annually, a documented risk assessment is performed covering: the asset and data inventory, the threat landscape for a firm holding regulated clients' governance evidence, third-party exposure, the control environment, and changes since the last assessment.

Output: an updated register, a set of treatments with owners and dates, and a written summary that can be provided to clients under NDA.

DECIDE — the month. Pick one, and pick it so it lands before the busiest client due-diligence season rather than during it.

9. Reporting

Critical and High residual risks are reported to the CEO on identification. The register is reviewed in full DECIDE — recommend quarterly, with the date, attendees and decisions recorded.

10. Known concentrations

Recorded here because an assessment that omits them is not credible, and clients will identify them unprompted.

Key person	A firm of this size concentrates knowledge and access in very few people. Mitigation in BCDR §4.4
Evidence concentration	Centience holds a map of which client organizations are weak where. Constitution Rule 11 treats this as a custodial obligation. It is also a target
Provider concentration	Application, database and authentication rest on a small number of providers. Deliberate, and the risk is the inability to act independently of them
Self-assessment tension	Centience operates controls and produces evidence about them. Mitigated by never claiming independence — an independent assessor consumes our evidence rather than competing with it

12 Onboarding and Offboarding Policy

DOCUMENT OWNER VERIFY — security lead VERSION 1.0 — draft · Effective VERIFY · Review annually

CLASSIFICATION Internal — releasable to clients and prospects

1. Why this is a security policy

Joiner, mover and leaver is where access control succeeds or fails in practice. A firm can have excellent policies and still leave a departed contractor's API token live for six months.

Each step produces a record. A checklist completed and filed is the evidence; a checklist followed from memory is not.

2. Before a joiner starts

Background check	DECIDE — conduct them, or document the decision not to and the reasoning. Either is defensible; silence is not, and client DDQs ask this directly.
Confidentiality agreement	Signed before any access
Contract or engagement letter	Executed
Role defined	Determines the access template applied

3. Onboarding

Step	Owner	Evidence
Identity created in Entra ID, MFA enrolled	VERIFY	Account record
Device issued, encrypted, enrolled in NinjaRMM	VERIFY	Device record
Access granted from the role template , not copied from a colleague	VERIFY	Access register entry
Password manager access provisioned	VERIFY	
Policies issued and acknowledged — Information Security, Acceptable Use	VERIFY	Signed acknowledgement
Security awareness training assigned	VERIFY	Completion record
Client confidentiality obligations explained	Manager	Onboarding record

Access is granted from the role template. Copying an existing person's access is how privilege accumulates invisibly across a firm, and it is one of the findings Centience most often writes for clients.

Platform access to client organizations is granted per engagement, not per person, and only for clients the individual is actually working on.

4. Movers

A change of role is not additive.

Access is **re-derived from the new role**, and access belonging only to the previous role is removed. The review is recorded with the date and the resulting changes.

This is the step most firms skip entirely, and it is why long-tenured staff often hold more access than anyone intended.

5. Offboarding

All access is revoked on the final working day, or immediately where the departure is involuntary or contentious.

Step	Owner	Evidence
Entra ID account disabled	VERIFY	Timestamp
Platform access revoked, all organizations	VERIFY	Timestamp
Production infrastructure access removed — Vercel, Supabase, GitHub	VERIFY	Timestamp
Third-party SaaS accounts disabled — HubSpot, Resend, NinjaRMM, Granola, Strac, others per the register	VERIFY	Per-system record
API tokens and personal access tokens revoked	VERIFY	Timestamp
Password manager access revoked, shared credentials rotated	VERIFY	Rotation record
Device returned and wiped	VERIFY	Device record
Mailbox handled per retention policy	VERIFY	
Confirmation that no client data is retained personally	Manager	Signed

The tokens row is the one that gets missed. Disabling the identity does not revoke a personal access token or an API key issued to that person. Each must be revoked explicitly.

Where the departing person held production access or credential-store access, rotate the credentials they could have read. Disabling their account does not un-know a secret.

6. Contractors

Contractors are onboarded and offboarded under this policy with no reduction. Where a contractor works through an agency, the confidentiality obligation is confirmed in writing before access.

Contractor access carries an **end date set at provisioning**, so that lapsed access expires by default rather than by someone remembering.

7. Verification

Offboarding completion is verified by someone other than the person who performed it, within **DECIDE — recommend 5 business days**, and the verification recorded.

The next scheduled access review (per Access Control §5) is the backstop, and is expected to find nothing.

13 Sub-Processor Register

DOCUMENT OWNER VERIFY — security lead VERSION 1.0 — draft · Effective VERIFY · Review annually and on change
CLASSIFICATION Internal — releasable to clients and prospects

Draft. Every row requires verification before release. The providers below are drawn from the technology actually in use; the **DPA, SOC 2 and 72-hour columns are unverified** and must be completed from the contracts and reports on file. A register with unverified assurance claims is worse than no register — it is a documented misstatement.

1. What this is

Every third party that may process, store or access information Centience holds on behalf of clients, or that is material to delivering the service.

Clients are entitled to this list. Material changes are notified per Vendor Management §7.

2. Critical — handle Class 1 client information

Provider	Purpose	Data	Region	DPA	SOC 2	72-hr notice
Vercel	Application hosting, serverless execution	Client data in transit through the application	VERIFY	VERIFY	VERIFY — type & period	VERIFY
Supabase	Database, authentication, object storage, edge functions	Primary store — findings, evidence, policies, attestations, encrypted credentials	VERIFY	VERIFY	VERIFY	VERIFY
Anthropic	Model inference; Enterprise API for client AI adoption metrics	Content submitted for analysis; client AI usage metadata	VERIFY	VERIFY	VERIFY	VERIFY
Microsoft	Graph API access to client tenants; Entra ID; Microsoft 365 for the firm	Client environment configuration; firm email and documents containing client information	VERIFY	VERIFY	VERIFY	VERIFY
Strac	Data loss prevention, where in a client's scope	Content inspected for sensitive data	VERIFY	VERIFY	VERIFY	VERIFY
NinjaRMM	Endpoint telemetry feeding shadow-AI discovery	Device and software inventory from client endpoints	VERIFY	VERIFY	VERIFY	VERIFY
Granola	Meeting recording and transcription	Client call recordings and transcripts	VERIFY	VERIFY	VERIFY	VERIFY

Granola deserves a second look. It processes recordings of client conversations, which are Class 1 by any reading, and it is the kind of tool adopted for convenience rather than through vendor diligence. Confirm the terms, the retention setting and that participants are consistently told. This is exactly the finding Centience writes for clients.

Prompt Security VERIFY — add as a row if the DLP layer moves there. \$2.50/user/month with no minimum was quoted directly; the diligence has not been done.

3. Important — Centience confidential data

Provider	Purpose	Data	DPA	SOC 2
GitHub	Source control, CI	Source code, infrastructure configuration. No client data, no secrets	VERIFY	VERIFY
HubSpot	CRM, marketing	Client and prospect contacts, pipeline	VERIFY	VERIFY
Resend	Transactional email	Recipient addresses, message content	VERIFY	VERIFY
VERIFY Password manager	Credential storage	Credentials	VERIFY	VERIFY
VERIFY Accounting / payroll	Finance	Employee and financial records	VERIFY	VERIFY

4. Client-directed

Where a client directs Centience to integrate with a system of their choosing — an archiving provider, a model provider on their tenancy, a line-of-business application — that provider is the client's, not Centience's sub-processor. The integration is recorded in the client's own connector configuration.

Centience does not assume responsibility for the security of a system the client selected and contracted, and says so in the engagement agreement rather than leaving it ambiguous.

5. Completing this register

For each Critical row, obtain and record:

1. Data processing agreement — executed, with date
2. Current SOC 2 Type II or equivalent — with **period covered and expiry diarised**
3. Breach notification commitment and window — contractual, or documented notice and acknowledgement per Vendor Management §5
4. Sub-processor list — theirs
5. Data location
6. Complementary user entity controls from their report — **the obligations their assurance transfers to us**

Item 6 is the one most often skipped and the one an auditor will test.

6. Change log

Date	Change	Approved by
VERIFY	Register established	